



○○○학교



수신자 내부결재

(경유)

제목 ○○○학교 개인정보 보호 내부 관리계획 개정

1. 근거

- 가. 개인정보 보호법 제29조(안전조치의무) 및 같은 법 시행령 제30조(개인정보의 안전성 확보조치)
 나. 개인정보의 안전성 확보조치 기준 제4조(내부 관리계획의 수립·시행)
 다. ○○○학교- (2019. 9. .) “개인정보 보호 내부 관리계획 개정”

2. 개인정보의 안전성 확보 조치를 위한 “○○○학교 개인정보 보호 내부 관리계획”을 붙임과 같이 개정하고자 합니다.

○ 주요 개정사항

- 「교육부 개인정보 보호지침」 개정에 따른 개정사항 등 반영

붙임 ○○○학교 개인정보 보호 내부 관리계획 1부. 끝.

★

교장

협조자

시행 ○○○학교-0000 (0000. 00. 00.) 접수 ()
 우 00000 경상남도 ○○○ / http://www.
 전화 000-0000 /전송 055-000-0000 / ○○○@○○○ / 비공개(5)

근거	- 개인정보 보호법 제29조(안전조치의무) - 개인정보 보호법 시행령 제30조(개인정보의 안전성 확보 조치) - 개인정보의 안전성 확보조치 기준 제4조(내부 관리계획의 수립·시행 및 점검)																
추진시기	- 내부 관리계획 개정: 변경 사유 발생 시(법령, 지침 변경 등) - 내부 관리계획 이행실태 점검: 연 1회 이상(9월 ~ 10월)																
세부 추진내용	■ 개인정보 보호 내부 관리계획이란? 기관(학교)이 취급하는 개인정보를 체계적으로 관리하고 안전하게 처리하기 위하여 내부 의사결정 절차를 통하여 수립·시행하는 관리적·기술적·물리적 안전조치 내부 기준 을 말함(법 제29조에 따른 의무사항) ※ ‘내부 관리계획’과 ‘개인정보 처리방침’, ‘개인정보 보호 업무추진계획’은 별개 <table><tr><th>구분</th><th>교육행정기관</th><th>학교</th><th>비고</th></tr><tr><td>개인정보 보호 내부 관리계획 수립</td><td>○</td><td>○</td><td>의무사항</td></tr><tr><td>개인정보 처리방침 수립</td><td>○</td><td>○</td><td>의무사항</td></tr><tr><td>개인정보 보호 업무추진계획 수립</td><td>○</td><td>×</td><td>학교는 도교육청 계획을 준용</td></tr></table> — <내부 관리계획에 포함되어야 할 필수사항(지침 제4조)> — 1. 개인정보 보호 조직의 구성 및 운영에 관한 사항 2. 개인정보 보호책임자의 자격요건 및 지정에 관한 사항 3. 개인정보 보호책임자와 개인정보취급자의 역할 및 책임에 관한 사항 4. 개인정보취급자에 대한 관리·감독 및 교육에 관한 사항 5. 접근 권한의 관리에 관한 사항 6. 접근 통제에 관한 사항 7. 개인정보의 암호화 조치에 관한 사항 8. 접속기록 보관 및 점검에 관한 사항 9. 악성프로그램 등 방지에 관한 사항 10. 개인정보의 유출, 도난 방지 등을 위한 취약점 점검에 관한 사항 11. 물리적 안전조치에 관한 사항 12. 개인정보 유출사고 대응 계획 수립·시행에 관한 사항 13. 위험 분석 및 관리에 관한 사항 14. 개인정보 처리업무를 위탁하는 경우 수탁자에 대한 관리 및 감독에 관한 사항 15. 개인정보 내부 관리계획의 수립, 변경 및 승인에 관한 사항 16. 그 밖에 개인정보 보호를 위하여 필요한 사항 ■ 준수사항 1. 개인정보 보호 내부 관리계획 수립(개정) 내부결재(개인정보 보호책임자 승인) 2. 내부 관리계획 결재 후 전 직원에게 전파(공람, 게시, 교육 등) 3. 내부 관리계획 이행실태 점검 및 결과 내부결재(개인정보 보호책임자) ※ 각급 학교 개인정보 보호책임자: 교장(지침 제21조(개인정보 보호책임자의 지정))  유의사항 ☞ 내부 관리계획은 매년 변경해야 하는 것은 아니며, 법·지침 개정 등에 따라 변경사항이 발생할 경우 개정하고, 변경 이력을 내부 관리계획에 포함하여 관리 ☞ 전 직원이 내부 관리계획을 준수할 수 있도록 결재 후 전 직원에게 공람	구분	교육행정기관	학교	비고	개인정보 보호 내부 관리계획 수립	○	○	의무사항	개인정보 처리방침 수립	○	○	의무사항	개인정보 보호 업무추진계획 수립	○	×	학교는 도교육청 계획을 준용
	구분	교육행정기관	학교	비고													
	개인정보 보호 내부 관리계획 수립	○	○	의무사항													
	개인정보 처리방침 수립	○	○	의무사항													
	개인정보 보호 업무추진계획 수립	○	×	학교는 도교육청 계획을 준용													
	벌칙 과태료	안전조치 의무 위반(법 제29조): 3천만원 이하의 과태료[법 제75조 제2항 제5호]															
	관련서류	- 내부 관리계획 수립(개정) 기안문 및 내부 관리계획 표준안(예시) - 내부 관리계획 이행실태 점검 결과 기안문 및 이행실태 점검표(예시)															

배움이 즐거운 학교 · 함께 가꾸는 경남교육

○○학교

개인정보 보호 내부 관리계획

20 . . .

작성방법

붉은색으로 표기된 부분과 빈 서식으로 된 부분을 학교 실정에 맞도록 수정하여 사용할 것.
Ctrl+H(찾아서 바꾸기) “○○학교” → “경남초등학교” 등으로 일괄 변경한 후, 그 외
항목은 학교별 실정에 맞도록 수정하여 사용할 것.(파란색은 이전 대비 변경사항을 표시,
글자색도 변경 할 것)

○○학교

개인정보 보호 내부 관리계획

제 · 개정 이력

시행일자	주요내용	작성자	공문 대호
2012. . .	- 개인정보 보호 내부 관리계획 제정	홍길동	○○학교-000 (20 . . .)
2014. . .	- 개인정보 보호 내부 관리계획 개정 · ○○ 추가 · ○○ 변경 등 “주요개정내용 및 개정이유 간략히 작성”	이순신	○○학교-000 (20 . . .)
2017. . .	- 개인정보 보호 내부 관리계획 개정 · 법 개정 및 개인정보의 안전성 확보조치 기준 개정 에 따른 변경 “주요개정내용 및 개정이유 간략히 작성”	정약용	○○학교-000 (20 . . .)
2018. 9. .	- 개인정보 보호 내부 관리계획 개정 · ○○ 추가 · ○○ 변경 등 “주요개정내용 및 개정이유 간략히 작성”	정약용	○○학교-000 (20 . . .)
2019. 9. .	- 개인정보의 안전성 확보조치 기준(제2019-47) 개정 사항 반영 ○ 접속기록 항목에 ‘처리한 정보주체 정보’ 추가(제3조제15호) ○ 제16조(접속기록 보관 및 점검) 변경 · 접속기록 보관 · 관리 연장: 6개월이상 → 1년이상 · 접속기록 점검주기 단축: 반기별 1회이상 → 월 1회 이상 · 개인정보를 다운로드한 경우 사유 확인(신설) - 교육부 정보보안 기본지침(2019.7.15.) 개정 사항 반영 ○ [별표 5] ‘저장매체 불용 시 파기방법’ 변경 - 별지서식 2호 ~ 7호 추가	정약용	
2021. 4. .	- 「교육부 개인정보 보호지침」개정(‘20.12.11.) 사항 등 반영 · 개인정보 정의 수정, 가명정보 등 용어 추가 · 개인정보의 목적 외 이용 · 제공 기준 수정 · 개인정보처리 위탁계약서 수정 · 가명처리에 관한 사항 추가 · 개인정보 침해사실 신고서 → 개인정보 유출사실 신고서	이순신	
2021. 9. .	- ‘바이오정보’→‘생체정보’로 용어 변경 및 개념 명확화	이순신	
2024. 1. .	- 개인정보의 안전성 확보조치 기준(제2023-6) 개정 사항 반영 ○ 개인정보를 인터넷망으로 송 · 수신시 암호화 의무 추가 (제16조) ○ 정당한 사유가 있는 경우 백신 · 보안 업데이트 지연 허용 (제18조) ○ 출력, 복사 시 안전조치 관련 내용 추가(제21조)	이순신	

목 차

제1장 총칙

제1조(목적)	1
제2조(적용범위)	1
제3조(용어 정의)	1
제4조(개인정보 보호 원칙)	4

제2장 내부 관리계획의 수립 및 시행

제5조(내부 관리계획의 수립 및 승인)	4
제6조(내부 관리계획의 공표)	5
제7조(내부 관리계획의 이행실태 점검·관리)	5

제3장 개인정보 보호조직에 관한 구성 및 운영

제8조(개인정보 보호조직 구성)	5
제9조(개인정보 보호책임자의 지정)	5
제10조(개인정보 보호책임자의 역할과 책임)	6
제11조(개인정보 보호담당자의 역할)	6
제12조(개인정보취급자의 범위 및 역할과 책임)	7

제4장 개인정보의 기술적·물리적 안전조치

제13조(접근권한의 관리)	7
제14조(비밀번호 관리)	8
제15조(접근통제)	8
제16조(개인정보의 암호화)	9
제17조(접근기록 보관 및 점검)	10
제18조(악성프로그램 등 방지)	10
제19조(관리용 단말기의 안전조치)	11
제20조(물리적 안전조치)	11
제21조(출력·복사시 안전조치)	11

제5장 개인정보 보호 교육

제22조(개인정보 보호 교육계획의 수립)	12
제23조(개인정보 보호 교육의 실시)	12

제6장 개인정보 처리의 위탁 및 수탁자 관리·감독

제24조(개인정보 처리 위탁 및 공개)	13
제25조(수탁자 교육 및 관리·감독)	13

제7장 개인정보의 이용 및 제공

제26조(개인정보의 추가적인 이용·제공 기준 등)	13
제27조(목적 외 이용 및 제3자 제공기준)	14
제28조(목적 외 이용 및 제3자 제공방법 및 절차)	15

제8장 개인정보 파기계획 및 절차

제29조(파기기준 및 파기기한)	16
제30조(파기절차)	16
제31조(파기방법)	16

제9장 개인정보 유출사고 대응 계획

제32조(개인정보 유출 등 신고체계)	17
----------------------	----

제10장 가명정보의 처리

제33조(가명정보의 처리 등)	18
제34조(가명정보에 대한 안전조치의무 등)	18
제35조(가명정보 처리 시 금지의무 등)	19

[별표 1] 개인정보 보호 조직 구성	20
[별표 2] 연간 개인정보 보호 교육계획	20
[별표 3] 개인정보의 목적 외 이용 및 제3자 제공 처리절차	21
[별표 4] 개인정보파일 파기절차	22
[별표 5] 저장매체 불용 시 파기방법	22
[별표 6] 가명정보 처리 절차	23
[별지 제1호 서식] 개인정보 내부 관리계획 이행실태 점검표	24
[별지 제2호 서식] 개인정보처리위탁 계약서	26
[별지 제3호 서식] 개인정보의 목적 외 이용 및 제3자 제공 대장	29
[별지 제4호 서식] 개인정보파일 파기 요청서	30
[별지 제5호 서식] 개인정보파일 파기 관리대장	31
[별지 제6호 서식] 개인정보 유출 사실 신고서	32
[별지 제7호 서식] 개인정보 유출신고(보고)서	33
[별지 제8호 서식] 가명정보 관리대장	34

제1장 총칙

제1조(목적)

개인정보 보호 내부 관리계획은 「개인정보 보호법」(이하 “법”이라 한다) 제29조(안전조치의무) 및 「개인정보 보호법 시행령」(이하 “시행령”이라 한다) 제30조(개인정보의 안전성 확보 조치)의 내부 관리계획 수립 및 시행 의무에 따라 제정된 것으로 ○○학교가 취급하는 개인정보를 체계적으로 관리하여, 개인정보처리자가 개인정보를 처리함에 있어 분실, 도난, 유출, 변조, 훼손, 오·남용 등이 되지 아니하도록 안전성을 확보하기 위한 최소한의 관리적·기술적·물리적 조치 계획을 수립하는 것을 목적으로 한다.

제2조(적용범위)

본 내부 관리계획은 정보통신망을 통하여 수집·이용·제공 또는 관리되는 개인정보 뿐만 아니라, 서면 등 정보통신망 이외의 수단을 통해서 수집·이용·제공 또는 관리되는 개인정보에 대해서도 적용되며, 이러한 개인정보를 취급하는 본교 내부 교직원 및 업무를 위탁받아 처리하는 외부업체 직원에 대해서도 적용한다.

제3조(용어 정의)

본 내부 관리계획에서 사용하는 용어의 정의는 다음 각 호와 같다.

1. “개인정보”란 살아있는 개인에 관한 정보로서 다음 어느 하나에 해당하는 정보를 말한다.
 - 가. 성명, 주민등록번호 및 영상 등을 통하여 개인을 알아볼 수 있는 정보
 - 나. 해당 정보만으로는 특정 개인을 알아볼 수 없더라도 다른 정보와 쉽게 결합하여 알아볼 수 있는 정보. 이 경우 쉽게 결합할 수 있는지 여부는 다른 정보의 입수 가능성 등 개인을 알아보는 데 소요되는 시간, 비용, 기술 등을 합리적으로 고려해야 한다.
 - 다. “가” 또는 “나”의 정보를 가명처리*함으로써 원래의 상태로 복원하기 위한 추가 정보의 사용·결합 없이는 특정 개인을 알아볼 수 없는 정보(이하 “가명정보”라 한다)

*가명처리: 개인정보의 일부를 삭제하거나 일부 또는 전부를 대체하는 등의 방법으로 추가 정보 없이는 특정 개인을 알아볼 수 없도록 처리하는 것

2. “정보주체”란 처리되는 정보에 의하여 알아볼 수 있는 사람으로서 그 정보의 주체가 되는 사람을 말한다.
3. “개인정보파일”이란 개인정보를 쉽게 검색할 수 있도록 일정한 규칙에 따라 체계적으로 배열하거나 구성한 개인정보의 집합물(集合物)을 말한다.
4. “개인정보처리자”란 업무를 목적으로 개인정보파일을 운영하기 위하여 스스로 또는 다른 사람을 통하여 개인정보를 처리하는 공공기관, 법인, 단체 및 개인 등을 말한다.
5. “개인정보 보호책임자”란 개인정보처리자의 개인정보 처리에 관한 업무를 총괄해서 책임지는 자로서 법 제31조 및 시행령 제32조제2항에 해당하는 자를 말한다.
6. “개인정보 보호담당자”란 각급 기관(학교)의 실질적인 개인정보 보호업무를 담당하는 자로 개인정보처리자가 지정한 자를 말한다.
7. “개인정보취급자”란 개인정보처리자의 지휘·감독을 받아 개인정보를 처리하는 업무를 담당하는 자로서 교직원, 파견근로자, 시간제근로자 등을 말한다.
8. “개인정보처리시스템”이란 데이터베이스시스템 등 개인정보를 처리할 수 있도록 체계적으로 구성된 응용시스템을 말한다.
9. “비밀번호”란 정보주체 또는 개인정보취급자 등이 개인정보처리시스템, 업무용 컴퓨터 또는 정보통신망 등에 접속할 때 식별자와 함께 입력하여 정당한 접속 권한을 가진 자라는 것을 식별할 수 있도록 시스템에 전달해야 하는 고유의 문자열로서 타인에게 공개되지 않는 정보를 말한다.
10. “정보통신망”이란 전기통신설비와 컴퓨터 및 컴퓨터의 이용기술을 활용하여 정보를 수집·가공·저장·검색·송신 또는 수신하는 정보통신체계를 말한다.
11. “공개된 무선망”이란 불특정 다수가 무선접속장치(AP)를 통하여 인터넷을 이용할 수 있는 망을 말한다.
12. “모바일 기기”란 무선망을 이용할 수 있는 PDA, 스마트폰, 태블릿PC 등 개인정보 처리에 이용되는 휴대용 기기를 말한다.
13. “생체정보”란 지문, 얼굴, 홍채, 정맥, 음성, 필적 등 개인의 신체적, 생리적, 행동적 특징에 관한 정보로서 특정 개인을 인증·식별하거나

개인에 관한 특징을 알아보기 위해 일정한 기술적 수단을 통해 처리되는 정보를 말한다.

13의2. “**생체인식정보**”란 생체정보 중 특정 개인을 인증 또는 식별할 목적으로 일정한 기술적 수단을 통해 처리되는 정보를 말한다.

14. “**휴대용 저장매체**”란 이동형 하드디스크, USB메모리, CD(Compact Disk), DVD(Digital Versatile Disk) 등 자료를 저장할 수 있는 매체로서 개인정보 처리시스템 또는 개인용 컴퓨터 등과 용이하게 연결·분리할 수 있는 저장매체를 말한다.

15. “**수탁자**”란 개인정보 처리 업무를 위탁받아 처리하는 자를 말한다.

16. “**접속기록**”이란 개인정보취급자 등이 개인정보처리시스템에 접속하여 수행한 업무내역에 대하여 개인정보취급자 등의 계정, 접속일시, 접속지 정보(접속한 자의 PC, 모바일기기 등 단말기 정보 또는 서버의 IP주소 등), 처리한 정보주체 정보, 수행업무(수집, 생성, 연계, 연동, 기록, 저장, 보유, 가공, 편집, 검색, 출력, 정정, 복구, 이용, 제공, 공개, 파기 등) 등을 전자적으로 기록한 것을 말한다. 이 경우 “접속”이란 개인정보처리시스템과 연결되어 데이터 송신 또는 수신이 가능한 상태를 말한다.

17. “**관리용 단말기**”란 개인정보처리시스템의 관리, 운영, 개발, 보안 등의 목적으로 개인정보처리시스템에 직접 접속하는 단말기(PC)를 말한다.

18. “**추가정보**”란 개인정보의 전부 또는 일부를 대체하는데 이용된 수단이나 방식(알고리즘 등), 가명정보와의 비교·대조 등을 통해 삭제 또는 대체된 개인정보 부분을 복원할 수 있는 정보를 말한다.

19. “**과학적 연구**”란 기술의 개발과 실증, 기초연구, 응용연구 및 민간 투자 연구 등 과학적 방법을 적용하는 연구를 말한다.

20. “**공익적 기록보존**”이란 공공의 이익을 위해 지속적으로 열람할 가치가 있는 기록정보를 보존하는 것을 말한다.

21. “**가명정보취급자**”란 가명정보를 처리하는 개인정보처리자의 지휘·감독을 받아 가명정보를 처리하는 직원, 파견근로자, 시간제근로자 등을 말한다.

22. “**익명정보**”란 시간·비용·기술 등을 합리적으로 고려할 때 다른 정보를 사용해도 더 이상 개인을 알아볼 수 없는 정보를 말한다.

23. “**익명처리**”란 개인정보의 전부 또는 일부를 데이터 값 삭제, 가명처리, 총계 처리, 범주화 등 다양한 기술을 적용함으로써 더 이상 특정 개인을 알아볼 수 없도록 익명정보로 처리하는 것을 말한다.

제4조(개인정보 보호 원칙)

- ① 개인정보의 처리 목적을 명확하게 하여야 하고, 그 목적에 필요한 범위에서 최소한의 개인정보만을 적법하고 정당하게 수집하여야 한다.
- ② 개인정보의 처리 목적에 필요한 범위에서 적합하게 개인정보를 처리하여야 하며, 그 목적외의 용도로 활용하여서는 아니 된다.
- ③ 개인정보의 처리 목적에 필요한 범위에서 개인정보의 정확성·완전성·최신성이 보장되도록 하여야 한다.
- ④ 개인정보의 처리 방법 및 종류 등에 따라 정보주체의 권리가 침해받을 가능성과 그 위험 정도를 고려하여 개인정보를 안전하게 관리하여야 한다.
- ⑤ 개인정보 처리방침 등 개인정보의 처리에 관한 사항을 공개하여야 하며, 열람 청구권 등 정보주체의 권리를 보장하여야 한다.
- ⑥ 정보주체의 사생활 침해를 최소화하는 방법으로 개인정보를 처리하여야 한다.
- ⑦ 개인정보를 익명 또는 가명으로 처리하여도 개인정보 수집목적 달성을 수 있는 경우 익명처리가 가능한 경우에는 익명에 의하여, 익명처리로 목적을 달성할 수 없는 경우에는 가명에 의하여 처리될 수 있도록 하여야 한다.
- ⑧ 이 내부 관리계획 및 관계 법령에서 규정하고 있는 책임과 의무를 준수하고 실천함으로써 정보주체의 신뢰를 얻기 위하여 노력하여야 한다.

제2장 내부 관리계획의 수립 및 시행

제5조(내부 관리계획의 수립 및 승인)

- ① 개인정보 보호책임자는 개인정보 보호와 관련한 법령 및 규정 등을 준수할 수 있도록 내부 관리계획을 수립하여야 한다.
- ② 개인정보 보호책임자는 개인정보 보호담당자가 보고한 내부 관리계획의 타당성을 검토하여 내부 관리계획을 승인하여야 한다.
- ③ 개인정보 보호담당자는 개인정보 보호와 관련한 법령 및 규정의 제·개정 사항을

반영하기 위하여 내부 관리계획의 타당성과 개정 필요성을 검토하여야 하며, 개정할 필요가 있다고 판단될 경우 내부 관리계획의 개정안을 작성하여 개인정보 보호책임자에게 보고하여 승인을 받아야 한다.

④ 개인정보 보호담당자는 내부 관리계획의 이력을 관리하여야 한다.

제6조(내부 관리계획의 공표)

- ① 개인정보 보호책임자는 제4조에 따라 승인된 내부 관리계획을 모든 교직원 및 관련자에게 알람으로써 이를 준수하도록 하여야 한다.
- ② 내부 관리계획은 전 교직원 등이 언제든지 열람할 수 있는 방법으로 비치하거나 제공하여야 하며, 변경사항이 있는 경우에는 이를 공지하여야 한다.

제7조(내부 관리계획의 이행실태 점검·관리)

- ① 개인정보 보호책임자는 개인정보 보호를 위한 내부 관리계획 및 관련 법령 등에서 정하는 개인정보 보호 규정을 성실히 이행하는지를 연 1회 이상 점검·관리하여야 한다.
- ② 개인정보 보호책임자는 개인정보 보호를 위한 이행실태 점검 결과 개인정보의 관리·운영상의 문제점 및 개인정보취급자의 위반사항에 대하여 시정·개선 등 필요한 조치를 취하여야 한다.
- ③ 내부 관리계획의 이행실태 점검 시 [별지 제1호 서식]의 점검표를 활용할 수 있다.

제3장 개인정보 보호조직에 관한 구성 및 운영

제8조(개인정보 보호조직 구성)

- ① 개인정보처리자는 개인정보 보호를 위하여 조직을 구성·운영한다.
- ② 개인정보 보호조직 구성은 [별표 1]과 같이 구성·운영한다.

제9조(개인정보 보호책임자의 지정)

- ① 다음 각 호의 해당하는 지위에 있는 자를 개인정보 보호책임자로 임명한다.
 - 1. 개인정보 보호책임자: 학교장(유치원인 경우 원장)

제10조(개인정보 보호책임자의 역할과 책임)

- ① 개인정보 보호책임자는 보유한 개인정보 보호를 위하여 다음 각 호의 임무 수행을 총괄한다.
 - 1. 내부 관리계획 및 개인정보 처리방침 등 개인정보 보호 관련 지침 수립·승인·시행
 - 2. 각종 개인정보 처리 실태 조사 및 개선
 - 3. 개인정보 처리와 관련한 불만 처리 및 피해 구제
 - 4. 교직원 및 개인정보취급자 등에 대한 개인정보 보호 교육계획의 수립·시행
 - 5. 개인정보파일의 보호 및 관리·감독
 - 6. 개인정보 보호 관련 자료의 관리
 - 7. 개인정보파일의 보유기간 산정
 - 8. 처리 목적이 달성되거나 보유기간이 지난 개인정보의 파기
 - 9. 가명정보 처리에 관한 사항
 - 10. 기타 개인정보 보호에 필요한 사항
- ② 개인정보 보호책임자는 개인정보취급자를 최소한으로 제한하여 지정하고 수시로 관리·감독하여야 하며, 교직원에 대한 교육 및 보안서약 등을 통해 개인정보 침해사고를 사전에 예방하여야 한다.
- ③ 개인정보 보호책임자는 개인정보 관련 업무의 효율적 운영을 위하여 교직원 중 1인 이상을 개인정보 보호담당자로 임명한다.

제11조(개인정보 보호담당자 역할)

개인정보 보호담당자는 개인정보 보호책임자를 보좌하여 개인정보보호 업무에 대한 실무를 총괄하고 관리하며, 다음 각 호의 임무를 수행한다.

- 1. 관련 법령의 개정 사항 등을 검토·반영한 내부 관리계획의 개정 보고
- 2. 개인정보 처리방침의 변경사항 관리 및 공개
- 3. 개인정보 처리 실태의 정기적인 조사 및 개선
- 4. 개인정보 처리와 관련한 요구 처리 및 개인정보 침해대응
- 5. 개인정보취급자 관리·감독과 교육 실시
- 6. 개인정보파일 등록·공개 및 관리
- 7. 개인정보보호 관련 자료 관리 및 제출 등

제12조(개인정보취급자의 범위 및 역할과 책임)

- ① 개인정보취급자의 범위는 개인정보처리자의 지휘·감독을 받아 개인정보 처리 업무를 수행하는 자를 말하며, 모든 교직원, 계약직, 파견근로자, 시간제근로자 및 계약에 의한 개인정보 처리 위탁 외부용역업체 직원 등을 포함한다.
- ② 개인정보취급자는 개인정보 보호와 관련하여 다음과 같은 역할 및 책임을 이행한다.
 1. 개인정보 보호 활동 참여
 2. 내부 관리계획 및 관련 법령, 규정의 준수 및 이행
 3. 개인정보의 관리적·기술적·물리적 안전조치 기준 이행
 4. 개인정보파일 관리
 5. 정보주체의 민원 신청접수 및 처리(열람, 정정, 변경, 삭제)
 6. 교직원 또는 제3자에 의한 위법·부당한 개인정보 침해행위에 대한 점검
 7. 개인정보 관련 개선 권고 및 시정 조치사항 이행
 8. 월1회 사이버보안전단의 날 PC 점검 및 고유식별정보 정비 및 암호화 관리
 9. 기타 개인정보 보호를 위해 필요한 사항의 이행

제4장 개인정보의 기술적·물리적 안전조치

제13조(접근권한의 관리)

- ① 개인정보처리자는 개인정보처리시스템에 대한 접근 권한을 개인정보취급자에게만 업무 수행에 필요한 최소한의 범위로 차등 부여하여야 한다.
- ② 개인정보처리자는 전보 또는 퇴직 등 인사이동이 발생하여 개인정보취급자가 변경되었을 경우 지체 없이 개인정보처리시스템의 접근 권한을 변경 또는 말소하여야 한다.
- ③ 개인정보처리자는 제1항 및 제2항에 의한 권한 부여, 변경 또는 말소에 대한 내역을 기록 관리하고, 그 기록을 최소 3년간 보관하여야 한다.
- ④ 개인정보처리자는 개인정보처리시스템에 접속할 수 있는 사용자계정을 발급하는 경우 개인정보취급자 별로 사용자계정을 발급하여야 하며, 다른 개인정보취급자와 공유되지 않도록 하여야 한다.

- ⑤ 개인정보처리자는 개인정보취급자 또는 정보주체의 인증수단을 안전하게 적용하고 관리하여야 한다.
- ⑥ 개인정보처리자는 정당한 권한을 가진 개인정보취급자 또는 정보주체만이 개인정보처리시스템에 접근할 수 있도록 일정 횟수 이상 인증에 실패한 경우 개인정보처리시스템에 대한 접근을 제한하는 등 필요한 조치를 취하여야 한다.

제14조(비밀번호 관리)

- ① 개인정보처리자는 개인정보취급자 또는 정보주체가 안전한 비밀번호를 설정하여 이행할 수 있도록 비밀번호 작성규칙을 수립하여 적용하여야 한다.
- ② 비밀번호는 문자, 숫자, 특수문자 등을 조합하여 구성한다.
- ③ 비밀번호는 정기적으로 변경하고 제3자에게 노출되었을 경우 즉시 새로운 비밀번호로 변경하여야 한다.
- ④ 비밀번호 부여는 추측하기 어려운 비밀번호로 생성·운영하여야 한다.
 1. 사용자 계정, 개인 신상정보 및 부서명칭 등 추측하기 쉬운 비밀번호 사용 금지
 2. 일련번호 또는 전화번호 등 쉬운 문자열 사용 금지
 3. love, happy 등 사전에 등록된 단어와 키보드 상 나란히 있는 문자열 포함 금지
 4. 사용된 비밀번호 재사용 금지 및 동일한 비밀번호 공유 금지
 5. 응용프로그램 등을 이용한 자동 비밀번호 입력기능 사용 금지
- ⑤ 민감정보나 중요 개인정보가 포함된 문서 등에는 파일별 비밀번호를 부여하여야 한다.

제15조(접근통제)

- ① 개인정보처리자는 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위해 다음의 사항을 포함한 시스템을 설치·운영하여야 한다.
 1. 개인정보처리시스템에 대한 접속 권한을 IP(Internet Protocol)주소로 제한하여 인가 받은 자만 접근할 수 있도록 제한
 2. 개인정보처리시스템에 접속한 IP(Internet Protocol)주소 등을 분석하여 불법적인 개인정보 유출 시도를 탐지하고 대응
- ② 개인정보처리자는 개인정보취급자가 정보통신망을 통해 외부에서 개인정보처리시스템에 접속하려는 경우에는 가상사설망(VPN: Virtual Private Network)이나 전용선 등 안전한 접속수단을 적용하거나 안전한 인증수단을 적용하여 접속

할 수 있도록 하여야 한다.

- ③ 개인정보처리자는 취급중인 개인정보가 인터넷 홈페이지, P2P, 공유설정, 공개된 무선망 이용 등을 통하여 열람권한이 없는 자에게 공개되거나 유출되지 않도록 개인정보처리시스템, 업무용 컴퓨터, 모바일 기기 및 관리용 단말기 등에 접근 통제 등에 관한 조치를 취하여야 한다.
- ④ 개인정보처리자는 고유식별정보를 처리할 경우 인터넷 홈페이지를 통하여 고유식별정보가 유출·변조·훼손되지 않도록 연 1회 이상 취약점을 점검하고 취약점 발견 시 보완 조치를 취하여야 한다.
- ⑤ 개인정보처리자는 개인정보취급자가 일정시간 이상 업무처리를 하지 않는 경우 자동으로 시스템 접속이 차단되도록 기술적 조치를 취하여야 한다.
- ⑥ 개인정보처리자가 별도의 개인정보처리시스템을 운영하지 아니하고 업무용 컴퓨터를 이용하여 개인정보를 처리하는 경우에는 제1항을 적용하지 아니할 수 있으며, 이 경우 업무용 컴퓨터의 운영체제(OS: Operating System)나 보안 프로그램 등에서 제공하는 접근 통제 기능을 이용할 수 있다.
- ⑦ 개인정보처리자는 업무용 모바일 기기를 사용할 경우 분실·도난 등으로 개인정보가 유출되지 않도록 해당 모바일 기기에 비밀번호 설정 등의 보호조치를 취하여야 한다.

제16조(개인정보의 암호화)

- ① 개인정보처리자는 비밀번호, 생체인식정보 등 인증정보를 저장 또는 정보통신망을 통하여 송·수신하는 경우에 이를 안전한 암호 알고리즘으로 암호화하여야 한다. 다만, 비밀번호를 저장하는 경우에는 복호화되지 아니하도록 일방향 암호화하여 저장하여야 한다.
- ② 개인정보처리자는 다음 각 호에 해당하는 이용자의 개인정보에 대해서는 안전한 암호 알고리즘으로 암호화하여 저장하여야 한다.
 - 1. 주민등록번호
 - 2. 여권번호
 - 3. 운전면허번호
 - 4. 외국인등록번호
 - 5. 계좌번호

6. 생체인식정보

- ③ 개인정보처리자는 이용자가 아닌 정보주체의 고유식별정보를 다음 각 호와 같이 저장하는 경우에는 암호화하여야 한다.
 - 1. 인터넷망 구간 및 인터넷망 구간과 내부망의 중간 지점(DMZ:Demilitarized Zone)에 고유식별정보를 저장하는 경우
 - 2. 내부망에 고유식별정보를 저장하는 경우(다만 주민등록번호 외의 고유식별정보를 저장하는 경우에는 다음 각 목의 기준에 따라 암호화의 적용 여부 및 적용범위를 정하여 시행할 수 있다)
 - 가. 법 제33조에 따른 개인정보 영향평가의 대상이 되는 공공기관의 경우에는 해당 개인정보 영향평가의 결과
 - 나. 암호화 미적용시 위험도 분석에 따른 결과
- ④ 개인정보처리자는 개인정보를 정보통신망을 통하여 인터넷망 구간으로 송·수신하는 경우에는 이를 안전한 암호 알고리즘으로 암호화하여야 한다.
- ⑤ 개인정보처리자는 정보주체의 고유식별정보, 생체인식정보를 개인정보취급자의 컴퓨터, 모바일 기기 및 보조저장매체 등에 저장할 때에는 안전한 암호 알고리즘을 사용하여 암호화한 후 저장하여야 한다.

제17조(접속기록 보관 및 점검)

- ① 개인정보처리시스템을 운영·관리하는 개인정보 보호책임자는 개인정보취급자가 개인정보처리시스템에 접속한 기록을 1년 이상 보관·관리하여야 한다. 다만, 5만명 이상의 정보주체에 관하여 개인정보를 처리하거나, 고유식별정보 또는 민감정보를 처리하는 개인정보처리시스템의 경우에는 2년 이상 보관·관리하여야 한다.
- ② 개인정보처리시스템을 운영·관리하는 개인정보 보호책임자는 개인정보의 오·남용, 분실·도난·유출·위조·변조 또는 훼손 등에 대응하기 위하여 개인정보처리시스템의 접속기록 등을 월 1회 이상 점검하여야 한다.
 - 비 인가된 개인정보 처리 및 대량의 개인정보 조회·정정·다운로드·삭제 등 비정상적 행위를 탐지하여 적절한 대응 조치 등
- ③ 특히 비정상적으로 개인정보를 다운로드 한 것이 발견되었을 경우에는 개인정보취급자에게 그 사유를 반드시 확인하여야 한다.

- 대량의 개인정보에 대한 다운로드 한 경우, 새벽시간, 휴무일 등 업무시간 외 개인정보를 다운로드 한 경우 등

④ 개인정보처리시스템을 운영·관리하는 개인정보 보호책임자는 개인정보취급자의 접속기록이 위·변조 및 도난, 분실되지 않도록 해당 접속기록을 안전하게 보관하여야 한다.

제18조(악성프로그램 등 방지)

① 개인정보처리자는 악성프로그램 등을 방지·치료할 수 있는 보안 프로그램을 설치·운영하여야 하며, 다음 각 호의 사항을 준수하여야 한다.

1. 프로그램의 자동 업데이트 기능을 사용하거나, 정당한 사유가 없는 한 일 1회 이상 업데이트를 실시하는 등 최신의 상태로 유지
2. 발견된 악성프로그램 등에 대해 삭제 등 대응 조치

② 개인정보처리자는 악성프로그램 관련 정보가 발령된 경우 또는 사용 중인 응용 프로그램이나 운영체제 소프트웨어의 제작업체에서 보안 업데이트 공지가 있는 경우 정당한 사유가 없는 한 즉시 이에 따른 업데이트 등을 실시하여야 한다.

제19조(관리용 단말기의 안전조치)

개인정보처리자는 개인정보 유출 등 개인정보 침해사고 방지를 위하여 관리용 단말기에 대하여 다음 사항에 대한 안전조치를 취하여야 한다.

1. 비인가자의 관리용 단말기 접근 제한으로 임의 조작을 못하도록 조치
2. 목적 내에서만 사용될 수 있도록 접근제한 및 접근통제 조치
3. 관리용 단말기에 개인정보 저장금지 및 방치 금지
4. 백신프로그램 설치 및 주기적 업데이트로 악성프로그램 등 감염 방지 조치

제20조(물리적 안전조치)

① 개인정보처리자는 전산실, 평가실, 자료보관실 등 개인정보를 보관하는 장소를 별도로 두고 있는 경우에는 물리적 장소에 대한 출입통제 절차를 수립·운영하여야 한다.

② 개인정보처리자는 개인정보가 포함된 서류, 휴대용 저장매체 등은 잠금장치가 있는 안전한 장소에 보관하여야 한다.

③ 개인정보처리자는 개인정보가 포함된 휴대용 저장매체의 반출·입 통제를 위한

보안대책을 마련하여야 한다.

제21조(출력·복사시 안전조치)

① 개인정보처리자는 개인정보처리시스템에서 개인정보의 출력시(인쇄, 화면표시, 파일생성 등) 용도를 특정하여야 하며, 용도에 따라 출력 항목을 최소화하여야 한다.

② 개인정보처리자는 개인정보가 포함된 종이 인쇄물, 개인정보가 복사된 외부 저장매체 등 개인정보의 출력·복사물을 안전하게 관리하기 위해 필요한 안전조치를 하여야 한다.

제5장 개인정보 보호 교육

제22조(개인정보 보호 교육계획의 수립)

① 개인정보 보호책임자는 다음 각 호의 사항을 포함하는 연간 개인정보 보호 교육계획을 수립·운영하여야 한다.

1. 교육목적 및 대상
2. 교육내용
3. 교육 일정 및 방법

② 개인정보 보호책임자는 수립한 개인정보 보호 교육계획을 실시한 이후에 교육의 성과와 개선 필요성을 검토하여 다음해 교육내용에 반영하여 수립한다.

③ 개인정보 보호 연간 교육계획은 [별표 2]와 같이하고, 개별 교육을 실시할 경우 별도의 세부 교육계획을 수립하여 실시한다.

제23조(개인정보 보호 교육의 실시)

① 개인정보 보호책임자는 개인정보 보호에 대한 직원들의 인식 제고를 위해 노력해야 하며, 개인정보의 오·남용 또는 유출 등을 적극 예방하기 위해 교직원을 대상으로 매년 정기적으로 연 1회 이상 개인정보 보호 교육을 실시하여야 한다.

② 교육 방법은 집합 교육 뿐만 아니라, 인터넷 교육 등 다양한 방법을 활용하여 실시하고, 필요한 경우 외부 전문기관이나 전문 강사를 초빙하여 교육을 실시할 수 있다.

- ③ 개인정보 보호에 대한 중요한 전파 사례가 있거나 개인정보 보호 업무와 관련하여 법 개정 등 변경된 사항이 있는 경우, 개인정보 보호책임자는 회의 등을 통해 수시 교육을 실시할 수 있다.
- ④ 개인정보 보호책임자는 제5장에 따라 개인정보 보호 교육을 실시한 결과 또는 이를 입증할 수 있는 관련 자료 등을 기록·보관하여야 한다.

제6장 개인정보 처리의 위탁 및 수탁자 관리·감독

제24조(개인정보 처리 위탁 및 공개)

- ① 개인정보처리자는 개인정보의 처리 업무를 위탁하는 경우에는 다음과 같이 문서화하여야 한다.
 - 법 제26조, 시행령 제28조의 필수 사항을 모두 포함한 계약서(표준 개인정보 처리위탁 계약서[별지 제2호 서식]·협약서·특약서 등을 작성)
- ② 개인정보처리자는 위탁하는 업무의 내용과 수탁자의 정보, 수탁자의 관리 현황 점검 결과 등 위탁에 관한 사항을 정보주체가 언제든지 쉽게 확인할 수 있도록 홈페이지에 지속적으로 게재하여 공개하여야 한다.

제25조(수탁자 교육 및 관리·감독)

- ① 개인정보처리자는 업무 위탁으로 인하여 정보주체의 개인정보가 분실·도난·유출·변조 또는 훼손되지 않도록 [별표 2]의 수탁자 교육계획에 따라 수탁자를 교육하고, 위탁계약서 내용 준수 및 안전성 확보 준수 여부, 개인정보 처리 현황 점검 등 수탁자가 개인정보를 안전하게 처리하는지 연 1회 이상 관리·감독하여야 한다.
- ② 수탁자 감독의 방법으로는 개인정보 처리량, 개인정보 위험성, 수탁자의 개인정보 보호 역량 등을 고려하여 현장방문 점검, 원격 점검, 자료제출 요구 및 확인 등 다양한 수단을 합리적으로 사용하여 감독을 시행할 수 있다.
- ③ 개인정보처리자는 수탁자를 교육하고 감독한 결과를 작성하여 보관하여야 한다.

제7장 개인정보의 이용 및 제공

제26조(개인정보의 추가적인 이용·제공 기준 등)

- ① 개인정보처리자는 당초 수집 목적과 합리적으로 관련된 범위에서 정보주체의 동의 없이 개인정보를 이용·제공할 수 있다.
- ② 개인정보처리자는 정보주체의 동의 없이 개인정보를 이용·제공하려는 경우에는 다음 각 호의 사항을 고려하여야 한다.
 1. 당초 수집 목적과 관련성이 있는지 여부
 2. 개인정보 수집 정황 또는 처리 관행에 비추어 볼 때 개인정보의 추가적인 이용 또는 제공에 대한 예측 가능성이 있는지 여부
 3. 정보주체의 이익을 부당하게 침해하는지 여부
 4. 가명처리 또는 암호화 등 안전성 확보에 필요한 조치를 하였는지 여부

제27조(목적 외 이용 및 제3자 제공기준)

- ① 개인정보처리자는 개인정보를 목적 외의 용도로 제3자에게 제공할 경우 다음 각 호의 사항에 대하여 종합적으로 검토한 후 제공여부를 판단하여야 하며, 필요한 최소한의 범위 내에서 제공하여야 한다.
 1. 자료 제공 판단 기준
 - 가. 목적 정당성: 구체적으로 어떠한 목적을 위하여 당해 개인정보가 필요한지?
 - 나. 수단 적정성: 당해 개인정보를 제공함으로써 공익목적을 달성할 수 있는지?
 - 다. 피해 최소화성: 목적 달성을 위하여 필요한 최소한의 정보는 어디까지인지?
 - 라. 법익 균형성: 제공에 따른 이익과 정보주체가 받을 수 있는 예상피해를 비교하여 전자가 우월하다고 할 수 있는지 여부 판단
 2. 요청 기관의 적격 여부
 - 가. 요청 기관의 개별법에 자료요청의 근거조항이 구체적으로 명시된 경우 제공 가능
 - 나. 요청 기관의 개별법에 자료요청 근거법이 없는 경우, 정보주체의 별도 동의가 있었는지 여부 등 예외적 제공 가능 사항에 해당되는지 확인한 후 제공 여부 결정
 3. 제공항목 판단
 - 가. 직접 수집한 정보 여부 확인: 직접 수집·생산한 정보가 아닌 경우 자료 제공 불가 ※ 단, 정보주체의 별도 동의가 있는 경우 제공 가능

나. 요청 목적에 부합하는 최소 항목만 제공(개인정보 최소 제공 원칙)

다. 주민등록번호는 법 제24조의2 제1항제1호에 따라 법률, 대통령령 등에서 처리를 요구(허용)한 경우만 제공 가능

② 개인정보처리자는 개인정보를 수집 목적 외의 용도로 이용하거나 목적 외의 용도로 제3자에게 제공하고자 하는 경우, 법 제18조제2항의 각 호에 해당되는 경우에 한해 예외적으로 제공할 수 있다. 다만, 정보주체 또는 제3자의 권익을 부당하게 침해할 우려가 있을 경우 제공이 불가능하다.

1. 정보주체로부터 별도의 동의를 받은 경우
2. 다른 법률에 특별한 규정이 있는 경우
3. 정보주체 또는 그 법정대리인이 의사표시를 할 수 없는 상태에 있거나 주소 불명 등으로 사전 동의를 받을 수 없는 경우로서 명백히 정보주체 또는 제3자의 급박한 생명, 신체, 재산의 이익을 위하여 필요하다고 인정되는 경우
4. 개인정보를 목적 외의 용도로 이용하거나 이를 제3자에게 제공하지 아니하면 다른 법률에서 정하는 소관 업무를 수행할 수 없는 경우로서 보호위원회의 심의·의결을 거친 경우
5. 조약, 그 밖의 국제협정의 이행을 위하여 외국정부 또는 국제기구에 제공하기 위하여 필요한 경우
6. 범죄의 수사와 공소의 제기 및 유지를 위하여 필요한 경우
7. 법원의 재판업무 수행을 위하여 필요한 경우
8. 형(刑) 및 감호, 보호처분의 집행을 위하여 필요한 경우

제28조(목적 외 이용 및 제3자 제공방법 및 절차)

- ① 개인정보처리자는 개인정보를 목적 외의 용도로 제3자에게 제공하는 경우 개인정보 보호책임자의 승인을 받아 제공하여야 하며, 승인 절차 진행 시 개인정보를 제공받는 자에게 이용 목적, 이용 방법, 이용 기간, 이용 형태 등을 제한하거나, 개인정보의 안전성 확보를 위하여 필요한 구체적인 조치를 마련 하도록 문서(전자문서 포함)로 요청하여 개인정보의 안전성 확보 조치에 관한 책임관계를 명확히 하여야 한다.
- ② 개인정보처리자는 개인정보를 목적 외의 용도로 이용하거나 목적 외의 용도로 제3자에게 제공하는 경우, 개인정보의 목적 외 이용 및 제3자 제공 대장 [별지

제3호 서식]에 기록·관리하여야 한다.

③ 개인정보처리자는 개인정보를 목적 외의 용도로 이용하거나 목적 외의 용도로 제3자에게 제공하는 경우, 이용 또는 제공한 날부터 30일 이내에 법적 근거, 목적, 개인정보의 항목, 이용·제공한 날짜 등 필요한 사항을 홈페이지에 10일 이상 계속 게재하여 공개하여야 한다. 다만, 본 내부 관리계획 제26조제2항1호에 의한 정보주체의 별도 동의를 받은 경우, 제26조제2항6호 수사 목적인 경우는 제외한다.

④ 개인정보의 목적 외 이용 및 제3자 제공 세부적인 절차는 [별표 3]에 따른다.

제8장 개인정보 파기계획 및 절차

제29조(파기기준 및 파기기한)

개인정보처리자는 개인정보의 보유기간이 경과된 경우, 개인정보의 처리 목적 달성, 해당 서비스의 폐지, 사업의 종료 등 그 개인정보가 불필요하게 되었을 때에는 지체 없이(정당한 사유가 없는 한 그로부터 5일 이내) 그 개인정보를 파기하여야 한다. 다만, 다른 법령에 따라 보존하여야 하는 경우에는 관련법에 따라 처리하며 해당 개인정보 또는 개인정보파일은 다른 개인정보와 분리하여 저장·관리하여야 한다.

제30조(파기절차)

- ① 개인정보처리자는 개인정보의 파기에 관한 사항을 기록·관리하여야 하며, 개인정보의 파기 시행 및 확인은 개인정보 보호책임자의 책임하에 수행되어야 한다.
- ② 개인정보취급자는 보유기간 경과 및 처리목적 달성한 개인정보파일을 선정하고, 개인정보파일 파기 요청서[별지 제4호 서식]에 기재하여 개인정보 보호책임자의 승인을 받아 개인정보를 파기하여야 하며, 개인정보 보호 책임자는 파기가 시행된 후 파기 결과를 확인하고 개인정보파일 파기 관리 대장[별지 제5호 서식]에 기록 관리하여야 한다. 세부적인 파기 절차는 [별표 4]에 의한다.

제31조(파기방법)

① 개인정보취급자는 개인정보를 파기할 경우 다음 각 호 중 어느 하나의 조치를 하여야 하며, 저장매체 불용 시 파기 방법은 [별표 5]에 따른다.

1. 완전파괴(소각·파쇄 등)
2. 전용 소자장비를 이용하여 삭제
3. 데이터가 복원되지 않도록 초기화 또는 덮어쓰기 수행

② 개인정보처리자가 개인정보의 일부만을 파기하는 경우, 제1항의 방법으로 파기하는 것이 어려울 때에는 다음 각 호의 조치를 취한다.

1. 전자적 파일 형태인 경우: 개인정보를 삭제한 후 복구 및 재생되지 않도록 관리·감독
2. 제1호 외의 기록물, 인쇄물, 서면, 그 밖의 기록매체인 경우: 해당 부분을 마스킹, 천공 등으로 삭제

제9장 개인정보 유출사고 대응 계획

제32조(개인정보 유출 등 신고체계)

① 개인정보취급자는 1명이라도 정보주체에 관한 개인정보가 유출된 경우에는 즉시 [별지 제6호 서식]에 의거 개인정보 보호책임자 및 지도·감독기관에 보고하고, 개인정보 보호책임자는 [별지 제7호 서식]에 의거 유출내용 및 조치 결과를 72시간 이내에 상급기관을 경유 교육부에 보고하여야 한다. 다만 다음 각 호에 해당하는 경우 개인정보보호위원회 또는 한국인터넷진흥원에 신고하여야 한다.

1. 1천명 이상의 정보주체에 관한 개인정보가 유출등이 된 경우
2. 민감정보, 고유식별정보가 유출등이 된 경우
3. 외부로부터의 불법적인 접근에 의해 개인정보가 유출등이 된 경우

② 또한 유출되었음을 알게 된 때에는 정당한 사유가 없는 한 72시간 이내에 해당 정보주체에게 서면, 전자우편, 모사전송, 전화, 휴대전화 문자전송 등의 방법을 통해 다음 각 호의 사항을 알려야 한다. 다만, 유출된 개인정보의 확산 및 추가 유출 방지를 위한 긴급한 조치(접속경로의 차단, 취약점 점검·보완, 유출된 개인정보의 삭제 등) 필요 시 조치 후 지체 없이 알릴 수 있다.

1. 유출된 개인정보의 항목
 2. 유출된 시점과 그 경위
 3. 유출로 인하여 발생할 수 있는 피해 최소화를 위해 정보주체가 할 수 있는 방법 등
 4. 개인정보처리자의 대응조치 및 피해 구제절차
 5. 정보주체에게 피해가 발생한 경우 신고 등을 접수할 수 있는 담당부서 및 연락처
- ③ 제2항에도 불구하고 정보주체의 연락처를 알 수 없는 등 정당한 사유가 있는 경우 인터넷 홈페이지에 정보주체가 알아보기 쉽도록 본 내부 관리계획 제31조제2항의 유출 통지 사항을 7일 이상 게재하여야 한다.
- ④ 그 외 개인정보 유출통지 방법과 신고 관련 세부적인 내용은 “경상남도교육청 개인정보 유출사고 대응 매뉴얼”에 따른다.

제10장 가명정보의 처리

제33조(가명정보의 처리 등)

- ① 개인정보처리자는 통계작성, 과학적 연구, 공익적 기록보존 등을 위해 정보주체의 동의 없이 가명정보를 처리할 수 있다.
- ② 개인정보처리자는 제1항에 따라 가명정보를 제3자에게 제공하는 경우, 특정 개인을 알아보기 위해 사용될 수 있는 정보를 포함해서는 아니 된다.
- ③ 제1항에도 불구하고 통계작성, 과학적 연구, 공익적 기록보존 등을 위해 서로 다른 개인정보처리자 간 가명정보의 결합은 개인정보보호위원회 또는 교육부장관이 지정하는 전문기관이 수행하며, 결합을 수행한 기관 외부로 결합된 정보를 반출할 때에는 가명정보 또는 익명정보로 처리한 뒤 전문기관 장의 승인을 받아야 한다.
- ④ 가명정보 처리에 대한 세부 절차는 “[별표 6] 가명정보 처리 절차” 따르며 별도로 정하지 않은 사항은 “교육분야 가명·익명 처리 가이드라인” 따른다.

제34조(가명정보에 대한 안전조치의무 등)

- ① 개인정보처리자는 가명정보를 처리하는 경우, 원래 상태로 복원하기 위한 추가 정보를 별도로 분리하여 보관·관리하는 등 해당 정보가 분실·도난·유출·위조·변조 또는 훼손되지 않도록 안전성 확보에 필요한 기술적·관리적·

물리적 조치를 하여야 한다.

1. "제4장"에 따른 안전성 확보 조치

2. 가명정보와 추가정보의 분리 보관. 다만, 추가정보가 불필요한 경우에는 추가정보를 파기해야 한다.

3. 가명정보와 추가정보에 대한 접근 권한의 분리

② 개인정보처리자는 가명정보를 처리하고자 하는 경우, 가명정보 처리에 관한 사항을 " [별지 제8호 서식]가명정보 관리대장"에 기록·보관하여야 한다.

제35조(가명정보 처리 시 금지의무 등)

① 누구든지 특정 개인을 알아보기 위한 목적으로 가명정보를 처리해서는 아니 된다.

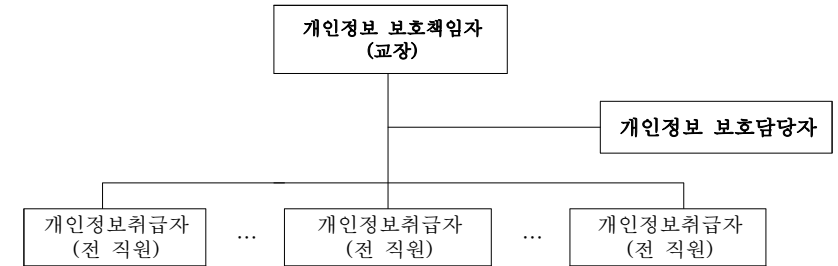
② 개인정보처리자는 가명정보를 처리하는 과정에서 특정 개인을 알아볼 수 있는 정보가 생성된 경우에는 즉시 해당 정보의 처리를 중지하고, 지체 없이 회수·파기하여야 한다.

부칙

본 내부 관리계획은 20 . . .부터 시행한다.

[별표 1]

개인정보 보호 조직 구성



[별표 2]

개인정보 보호 연간 교육계획

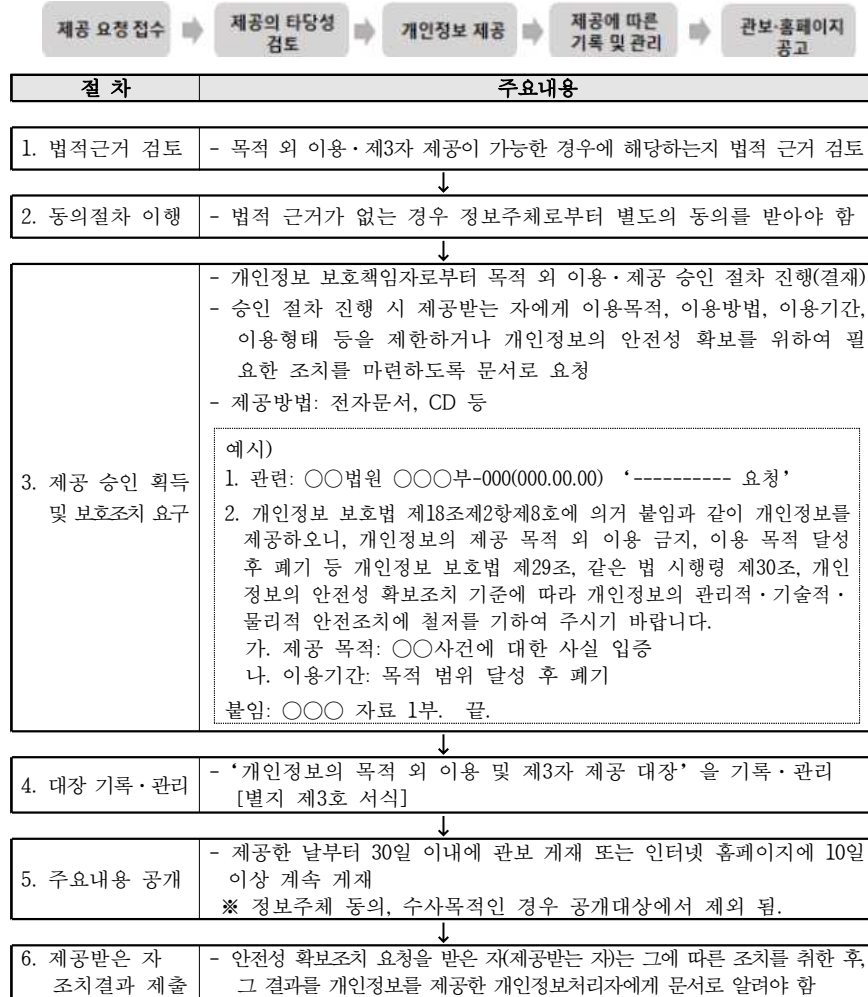
○ 교육목적: 개인정보 보호 인식제고 및 침해사고 예방, 전문성 역량 강화

대상	일정	교육 시기	교육방법	교육내용
개인정보 보호책임자 (CPO)		상반기	감독기관의 CPO교육 (집합교육 또는 온라인 교육)	- 개인정보 보호책임자의 역할과 의무 - 개인정보 보호 주요 추진정책 - 개인정보 보호법의 이해 - 개인정보 유출사례 등
개인정보 보호담당자		상시	감독기관의 교육 (집합교육 또는 온라인 교육)	- 개인정보 보호법의 이해 - 개인정보 처리단계별 준수사항 - 개인정보의 안전성 확보조치 방안 - 개인정보 유출사례 및 침해사고 대응 등
개인정보 취급자 (전 직원)		상시	자체교육 또는 온라인 교육	- 개인정보 보호 내부 관리계획 · 수집·이용 방법 · 목적 외 이용 및 제3자 제공 및 절차 · 개인정보 위탁, 수탁자 관리 방법 · 안전성 확보 조치
전입자		전입 시	자체 교육	- 개인정보 유출사고 대응방법 및 절차 - 개인정보 위반 사례 등
수탁자		위탁 시 점검 시	자체 교육	- 개인정보 위탁에 따른 수탁자 책임과 의무 - 개인정보 처리방법 및 안전성 확보조치 - 위탁계약서 및 과태료 부과기준 등

[별표 3]

개인정보의 목적 외 이용 및 제3자 제공 처리절차

○ 목적 외 이용 및 제3자 제공 처리절차

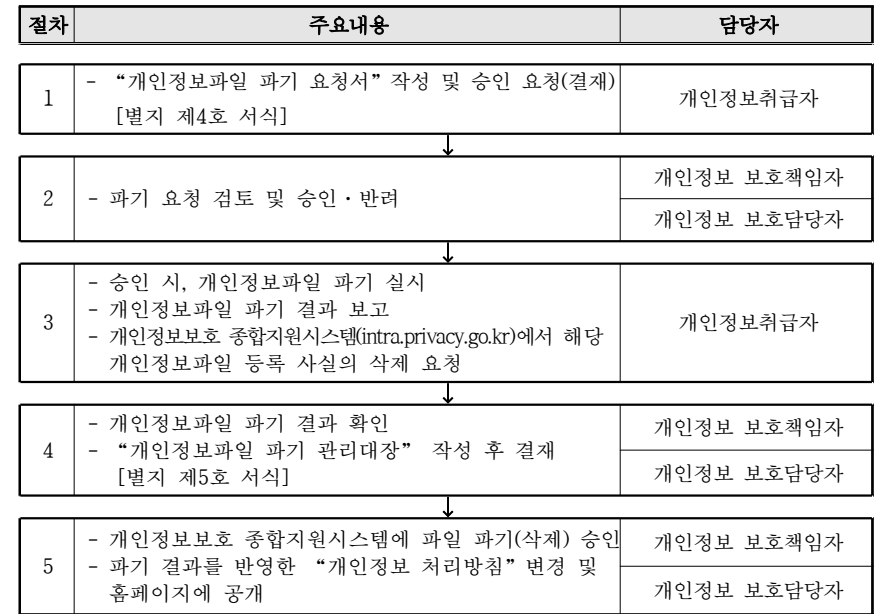


○ 목적 외 이용·제3자 제공 시 주요내용 공개

제공하는 개인정보	제공받는 기관	제공 법적 근거	제공받는 자의 이용 목적	제공하는 개인정보항목	제공날짜 또는 제공주기(기간)

[별표 4]

개인정보파일 파기절차



[별표 5]

저장매체 불용 시 파기방법

저장 자료 저장 매체	공개 자료	비공개 자료	대외비 자료	비밀 자료
자기테이프 플로피디스크	자체 판단	물리적 파괴	물리적 파괴	물리적 파괴
광디스크 (CD·DVD 등)	자체 판단	물리적 파괴	물리적 파괴	물리적 파괴
반도체메모리 (SSD·USB 등)	포맷 또는 삭제	물리적 파괴	물리적 파괴	물리적 파괴
하드디스크	포맷 또는 삭제	디가우징 또는 완전삭제 S/W	물리적 파괴	물리적 파괴

☞ 경상남도교육청 정보보안 기본지침(2021.3.19.) [부록3] 정보시스템 저장매체 불용처리지침 참고

가명정보 처리 절차

단계	내용
1. 사전준비	○ (처리 목적 및 대상 명확화) 가명처리 목적을 명확히 정의하고 가명처리 적합성 검토 ○ (가명처리 수행 승인) 가명처리 관련 계획 수립(개인정보 보호책임자 결재), 회의 개최 - 가명정보 안전성 확보 조치 및 접근관리 방안 수립, 가명정보 취급자 지정 등 - 가명처리 위탁 또는 가명정보 제3자 제공 시, 계약서(안) 마련 ○ (처리 대상 정보집합물 구성) 가명처리 목적 달성에 필요한 최소한의 항목을 추출하여 가명처리 대상 정보집합물 구성
2. 가명처리	○ (가명처리 대상 항목 선정) 목적에 따른 처리 대상 확인 및 처리항목 추출 ○ (위험도 측정) 가명처리 환경, 개인정보 항목별 위험도 측정 ○ (가명처리 수준 정의) 가명처리 방법과 수준 결정 ○ (가명처리 수행) 가명처리 수준정의를 기반으로 가명처리 수행 ○ (보완 조치) 가명처리 결과물에 대한 개인정보 재식별 모니터링
3. 적정성 검토	○ (적정성 검토) 가명처리의 적정성, 목적 달성 가능성 등 검토. 필요시 적정성 검토 위원회 구성 가능
4. 활용 및 사후관리	○ (기록 관리) 가명정보 처리 관련 내용 기록, 보관·관리 ☞ [별지 제8호 서식, 가명정보 관리대장] ○ (재식별 모니터링) 재식별 여부 모니터링 ○ (가명정보 처리 중단 등) 개인정보가 재식별된 경우 즉시 가명정보 처리 중단 및 즉시 삭제(파기) 등의 조치 수행

개인정보 내부 관리계획 이행실태 점검표

□ 점검일 :

점검항목	세부 점검내용	점검결과
내부 관리계획 수립 및 책임자 공개	1. 개인정보 보호 내부 관리계획 수립 여부 - 12가지 필수 내용이 포함되어 있는지 확인	□예 □아니오
	1-1. 개인정보 보호책임자의 지정에 관한 사항	□예 □아니오
	1-2. 개인정보 보호책임자 및 취급자의 역할 및 책임에 관한 사항	□예 □아니오
	1-3. 개인정보취급자에 대한 교육에 관한 사항	□예 □아니오
	1-4. 접근 권한의 관리에 관한 사항	□예 □아니오
	1-5. 접근 통제에 관한 사항	□예 □아니오
	1-6. 개인정보의 암호화 조치에 관한 사항	□예 □아니오
	1-7. 접속기록 보관 및 점검에 관한 사항	□예 □아니오
	1-8. 악성프로그램 등 방지에 관한 사항	□예 □아니오
	1-9. 물리적 안전조치에 관한 사항	□예 □아니오
	1-10. 개인정보 보호조직에 관한 구성 및 운영에 관한 사항	□예 □아니오
	1-11. 개인정보 유출사고 대응 계획 수립·시행에 관한 사항	□예 □아니오
	1-12. 개인정보 처리업무를 위탁하는 경우 수탁자에 대한 관리 및 감독에 관한 사항	□예 □아니오
개인정보 보호 교육	2. 개인정보 처리방침에 개인정보 보호책임자를 현행화하여 공개 여부 ※ 각급 학교 개인정보 보호책임자: 교장	□예 □아니오
	3. 개인정보 보호 연간 교육계획 수립 여부 - 교육목적 및 대상(책임자, 담당자, 취급자, 수탁자), 내용, 일정 및 방법을 포함한 당해연도 종합적인 연간 교육계획 수립	□예 □아니오
	4. 개인정보 보호 교육 실시 여부	□예 □아니오
	4-1. 개인정보 보호책임자 CPO전문교육 이수 여부 * 온라인 또는 오프라인, 도교육청 온라인전달연수(gnleckr)	□예 □아니오
	4-2. 개인정보 보호담당자 교육 이수 여부 * 온라인 또는 오프라인, 도교육청 온라인전달연수(gnleckr)	□예 □아니오
접근권한 관리	4-3. 취급자(전직원) 교육 실시 여부 - 대상()명 / 참석()명, 교육이수율()%	□예 □아니오
	5. 개인정보처리시스템에 대한 접근 권한 관리 여부 - 개인정보처리시스템에 접근 권한을 최소한의 범위로 부여 여부 - 전보, 퇴직 등 인사이동 시 권한 변경 및 말소 여부 - 사용자별 접속 계정 발급 및 공유금지의 이행 여부 - 권한부여, 변경, 말소에 대한 내역을 기록·보관(3년) 여부 ※ 개인정보처리시스템: 나이스, K-에듀파인, 학교홈페이지 등 ※ 교육정보과-3659(2021. 6. 3.)"교육정보시스템 사용자 및 권한관리 지침 개정"참고	□예 □아니오

점검항목	세부 점검내용	점검결과
접속기록 보관 및 점검	6. 자체 운영·관리하는 개인정보처리시스템이 있을 경우 접속기록 점검 및 보관 여부 - 자체 운영·관리하는 개인정보처리시스템이 없을 경우 '해당없음'에 표기 * 업무포털, 통합홈페이지 등 통합하여 관리하는 시스템은 통합 운영·관리 기관에서 접속기록 보관·점검함	☐ 예 ☐ 아니오 ☐ 해당없음
접근통제 및 단말기 안전조치	7. 취급중인 개인정보가 인터넷 홈페이지, P2P, 공유설정 등을 통해 공개유출되지 않도록 업무용PC 모바일 기기 등에 접근통제 조치 여부 - PC 운영체제나 보안프로그램 등의 접근통제 조치 - 비밀번호 설정 - 화면보호기 비밀번호 설정(10분이상)	☐ 예 ☐ 아니오
암호화	8. 업무용PC에 고유식별정보(주민등록번호 등) 저장 시 암호화 여부 - PC개인정보관리시스템(Privacy-i)을 통한 암호화 여부	☐ 예 ☐ 아니오
악성프로 그램 방지	9. 업무용PC에 백신 소프트웨어 설치 운영 및 자동 업데이트 여부	☐ 예 ☐ 아니오
물리적 안전조치	10. 전산실, 평가실 등 개인정보 보관 장소의 물리적 통제 절차 적정 여부 예) 통제구역 지정, 출입명부 관리, 잠금장치 설정 등	☐ 예 ☐ 아니오
	11. 개인정보 포함 서류, 휴대용 저장매체는 잠금장치가 있는 안전한 장소에 보관 여부	☐ 예 ☐ 아니오
개인정보 처리 위탁	12. 개인정보 처리 위탁 시 문서화 여부 - 필수사항을 포함한 위탁계약서(개인정보 처리 표준위탁계약서) * PC유지관리, 졸업앨범제작 등	☐ 예 ☐ 아니오
목적 외 이용 및 제3자 제공	13. 개인정보의 목적 외 이용 및 목적 외 제3자 제공 절차 준수 여부 예) 국회, 경찰서, 법원, 병무청 등 자료 제공	☐ 예 ☐ 아니오 ☐ 해당없음
	13-1. 개인정보 보호책임자의 승인을 거쳐 제공받는자에게 문서로 보호조치 요청	☐ 예 ☐ 아니오 ☐ 해당없음
	13-2. 개인정보의 목적 외 이용 및 제3자 제공 대장 기록 관리	☐ 예 ☐ 아니오 ☐ 해당없음
	13-3. 목적 외 이용 및 제3자 제공 내역을 홈페이지 공개 ※ 정보주체의 별도 동의 범주의 수사를 위해 제공한 경우 공개 제외	☐ 예 ☐ 아니오 ☐ 해당없음
개인정보 파기 수행	14. 목적 달성, 보유기간 경과한 개인정보(파일)의 파기 여부 - 파기 요청서 및 개인정보파일 파기 관리대장 기록·관리	☐ 예 ☐ 아니오

※ 연 1회 이상 이행실태 점검 실시 후 개인정보 보호책임자(교장) 내부결재를 득하여 보관

※ 내부 관리계획이란? 기관(학교)이 취급하는 개인정보를 체계적으로 관리하고 안전하게 처리하기 위하여 내부 의사결정 절차를 통하여 수립·시행하는 기술적·관리적·물리적 안전조치 **내부 기준**을 말함(개인정보 보호법에 의거 의무 수립)

- 개정시기: 매년 수립할 필요가 없으며, 법령 개정 등으로 변경 사유가 발생할 경우 개정
- **내부 관리계획과 개인정보 보호 업무추진계획은 별개이며**, 학교에서는 업무추진계획 수립 없이 도교육청 업무추진계획을 준용하여 업무 추진

개인정보처리위탁 계약서

OO학교(이하 “위탁자” 라 한다)과 **△△△업체**(이하 “수탁자” 라 한다)는 “위탁자”의 개인정보 처리업무를 “수탁자”에게 위탁함에 있어 다음과 같은 내용으로 본 업무위탁계약을 체결한다.

제1조(목적) 이 계약은 “위탁자”가 개인정보처리업무를 “수탁자”에게 위탁하고, “수탁자”는 이를 승낙하여 “수탁자”의 책임아래 성실하게 업무를 완성하도록 하는데 필요한 사항을 정함을 목적으로 한다.

제2조 (용어의 정의) 본 계약에서 별도로 정의되지 아니한 용어는 「개인정보 보호법」, 같은 법 시행령, 「개인정보의 안전성 확보조치 기준」(개인정보보호위원회고시 제2023-6호) 및 「표준 개인정보 보호지침」(개인정보보호위원회고시 제2024-1호)에서 정의된 바에 따른다.

제3조 (위탁업무의 목적 및 범위) “수탁자”는 계약이 정하는 바에 따라 **OOO사업** 목적으로 다음과 같은 개인정보 처리 업무를 수행한다.¹⁾
1. ○○○
2. ○○○

제4조 (위탁업무 기간) 이 계약서에 의한 개인정보 처리업무의 기간은 다음과 같다.
계약기간: ○○○○년 ○월 ○일 ~ ○○○○년 ○월 ○일

제5조 (재위탁 제한) ① “수탁자”는 “위탁자”의 사전 승낙을 얻은 경우를 제외하고 “위탁자”와 계약상의 권리와 의무의 전부 또는 일부를 제3자에게 양도하거나 재위탁할 수 없다.
② “수탁자”가 다른 제3의 회사와 수탁계약을 할 경우에는 “수탁자”는 해당 사실을 계약 체결 7일 이전에 “위탁자”에게 통보하고 협의하여야 한다.

제6조 (개인정보의 안전성 확보조치) “수탁자”는 「개인정보 보호법」 제23조제2항 및 제24조제3항 및 제29조, 같은 법 시행령 제21조 및 제30조, 「개인정보의 안전성 확보조치 기준」(개인정보보호위원회고시 제2023-6호)에 따라 개인정보의 안전성 확보에 필요한 관리적·기술적·물리적 조치를 취하여야 한다.

제7조 (개인정보의 처리제한 및 파기) ① “수탁자”는 계약기간은 물론 계약 종료 후에도 위탁업무 수행 목적 범위를 넘어 개인정보를 이용하거나 이를 제3자에게 제공 또는 누설하여서는 안 된다.

② “수탁자”는 계약이 해지되거나 또는 계약기간이 만료된 경우 위탁업무와 관련하여 보유하고 있는 개인정보를 「개인정보 보호법 시행령」 제16조 및 「개인정보의 안전성 확보조치 기준」(개인정보보호위원회고시 제2023-6호)에 따라 즉시 파기하거나 “위탁자”에게 반납하여야 한다.

③ 제2항에 따라 “수탁자”가 개인정보를 파기한 경우 지체없이 “위탁자”에게 그 결과를 통보하여야 한다.

제8조 (수탁자에 대한 관리·감독 등) ① “위탁자”는 “수탁자”에 대하여 다음 각 호의 사항을 감독할 수 있으며, “수탁자”는 특별한 사유가 없는 한 이에 응하여야 한다.

1. 개인정보의 처리 현황
2. 개인정보의 접근 또는 접속현황
3. 개인정보 접근 또는 접속 대상자
4. 목적 외 이용·제공 및 재위탁 금지 준수여부
5. 암호화 등 안전성 확보조치 이행여부
6. 그 밖에 개인정보의 보호를 위하여 필요한 사항

② “위탁자”는 “수탁자”에 대하여 제1항 각 호의 사항에 대한 실태를 점검하여 시정을 요구할 수 있으며, “수탁자”는 특별한 사유가 없는 한 이행하여야 한다.

③ “위탁자”는 처리위탁으로 인하여 정보주체의 개인정보가 분실·도난·유출·변조 또는 훼손되지 아니하도록 1년에 ()회 “수탁자”를 교육할 수 있으며, “수탁자”는 이에 응하여야 한다.²⁾

④ 제1항에 따른 교육의 시기와 방법 등에 대해서는 “위탁자”는 “수탁자”와 협의하여 시행한다.

제9조 (정보주체 권리보장) “위탁자”는 정보주체의 개인정보 열람, 정정·삭제, 처리 정지 요청 등에 대응하기 위한 연락처 등 민원창구를 마련해야 한다.

제10조 (개인정보의 파기) ① “수탁자”는 제4조의 위탁업무기간이 종료되면 특별한 사유가 없는 한 지체 없이 개인정보를 파기하고 이를 “위탁자”에게 확인받아야 한다.

제11조 (손해배상) ① “수탁자” 또는 “수탁자”의 임직원 기타 “수탁자”의 수탁자가 이 계약에 의하여 위탁 또는 재위탁 받은 업무를 수행함에 있어 이 계약에 따른

의무를 위반하거나 “수탁자” 또는 “수탁자”의 임직원 기타 “수탁자”의 수탁자의 귀책사유로 인하여 이 계약이 해지되어 “위탁자” 또는 개인정보주체 기타 제3자에게 손해가 발생한 경우 “수탁자”는 그 손해를 배상하여야 한다.

② 제1항과 관련하여 개인정보주체 기타 제3자에게 발생한 손해에 대하여 “위탁자”가 전부 또는 일부를 배상한 때에는 “위탁자”는 이를 “수탁자”에게 구상할 수 있다.

제12조 (개인정보의 유출 통지) “수탁자”는 수탁 업무를 처리하는 과정에서 개인정보가 유출된 경우 즉시 “위탁자”에게 보고하고, 추가 유출 및 피해방지를 위해 필요한 조치를 수행하여야 한다.

본 계약의 내용을 증명하기 위하여 계약서 2부를 작성하고, “위탁자”와 “수탁자”가 서명 또는 날인한 후 각 1부씩 보관한다.

20 년 월 일

위탁자

경남 ○○시(군) ○○로 ○○

기관명 : ○○학교장 (직인)

수탁자

○○도(시) ○○시(군) ○○로 ○○

업체명 :

대 표 : (인)

1) 각호의 업무 예시 : 회원가입 및 운영 업무를 위한 이름, 연락처 처리 등

2) 「개인정보의 안전성 확보조치 기준」(개인정보보호위원회고시 제2023-6호)에 따라 개인정보처리자 및 취급자는 1년에 1회 이상 개인정보보호에 관한 교육을 의무적으로 시행하여야 한다.

개인정보의 목적 외 이용 및 제3자 제공 대장

개인정보 또는 개인정보파일 명칭	작성 예시) 학생 생활기록부 정보(1명)		
이용 또는 제공 구분	[] 목적 외 이용 [☒] 목적 외 제3자 제공		
목적 외 이용의 명칭 (목적 외 이용의 경우)		담당자	소 속
			성 명
			전화번호
제공받는 기관의 명칭 (제3자 제공의 경우)	○○법원 ○○○부서	담당자	성 명 ○○○ 소 속 ○○○부서 전화번호 055-○○○-○○○ ○
이용하거나 제공한 날짜, 주기 또는 기간	2020년 ○월 ○일		
이용하거나 제공한 형태	전자문서 제공(또는 사본 우편 제출 등 실제 제공방법으로 기재)		
이용 또는 제공의 법적 근거	개인정보 보호법 제18조제2항제8호 (요청 근거 법률 입력: 예, 병역법 제20조의3)		
이용 목적 또는 제공받는 목적	○○법원 사건 사실 입증		
이용하거나 제공한 개인정보의 항목	성명, 주소, 생년월일, 연락처		
「개인정보 보호법」 제18조제5항에 따라 제한을 하거나 필요한 조치를 마련할 것을 요청한 경우에는 그 내용	개인정보 보호법 제29조, 같은법 시행령 제30조, 개인정보의 안전성 확보조치 기준에 따라 개인정보의 관리적·기술적·물리적 안전조 치 요청		

개인정보파일 파기 요청서

작성일	예시) 2019. 8. 20.	작성자	김철수 (개인정보취급자 또는 개인정보 보호담당자)
파기 대상 개인정보파일	영재학생관리		
생성일자	2014. 3. 1.	개인정보취급자	김철수
주요 대상업무	영재학생 현황 관리	현재 보관건수	00건 (정보 주체수)
파기 사유	영재학급 운영 종료로 개인정보 파기		
파기 일정	2019. 8. 23.		
특기사항			
파기 승인일	2019. 8. 20.	승인자 (개인정보 보호책임자)	나국장 (서명) (전자결재 또는 서명)
파기 장소	○○학교 교무실		
파기 방법	신청서 파쇄 및 전자파일 완전삭제S/W로 삭제		
파기 수행자	김철수	입회자	김부장 (팀장, 부서장 등)
파기 확인 방법	입회하에 서면 및 전자파일 완전삭제 확인		
백업 조치 유무	없음		
매체 파기 여부	해당없음 (매체 불용 시 물리적 파괴, 전용소자장비처리, 완전삭제S/W)		

개인정보파일 파기 관리대장

번호	개인정보 파일명	자료의 종류	생성일	파기일	파기사유	처리담당자 (취급자)	처리부서장 (보호책임자)
1	영재학생 관리	서면 및 전자적파일	2014.3.1.	2019.8.23.	영재학급 운영 종료	김철수	나국장 (서명)

개인정보 유출 사실 신고서

결 재			개인정보 보호책임자		

기관(부서)명					
신고 일자					
신고 내용	- 발생(인지) 경로, 유출된 개인정보 항목, 유출 시점과 그 경위 및 기타 신고 사항 등				
담당부서 · 담당자 및 연락처	구분	성명	부서	직위	연락처
	(분야별) 개인정보 보호책임자				
	(분야별) 개인정보 보호담당자				
	개인정보 취급자				

개인정보 유출등 신고서

기관명					
유출등이 된 개인정보 항목 및 규모					
유출등이 된 시점과 그 경위					
유출등 피해 최소화를 위해 정보주체가 할 수 있는 방법 등					
개인정보처리자의 대응 조치 및 피해 구제절차					
정보주체에게 피해가 발생한 경우 신고 등을 접수할 수 있는 담당부서 및 연락처					
유출등 신고(보고) 담당자		성명	부서	직위	연락처
	개인정보 보호책임자				
	담당자 (취급자)				

유출등 신고 접수기관	기관명	담당자명	연락처

가명정보 관리대장

번호	기간	목적	항목	처리 및 보유기간	제공받는 자 등	위탁 사항	제한 사항	처리 구분	기타 사항	가명처리 수행자	책임자
1	가명처리 시작일 ~ 종료일			필요시 기재 예) 처리기간(년) 보유기간(년)				예) 생성 결함 제공 공개 등	예) 추가정보 동시 파기	홍길동	이순신

1.2. 내부 관리계획 이행실태 점검 결과 기안문 예시

배움이 즐거운 학교 · 함께 가꾸는 경남교육



○○학교



수신자 내부결재

(경유)

제목 ○○학교 개인정보 보호 내부 관리계획 이행실태 점검 결과 보고

1. 근거

- 가. 교육부 개인정보 보호지침 제35조(내부 관리계획의 수립·시행)
- 나. 개인정보의 안전성 확보조치 기준 제4조(내부 관리계획의 수립·시행)
- 다. ○○학교 개인정보 보호 내부 관리계획

2. 개인정보의 안전한 관리를 위하여 개인정보 보호 내부 관리계획 이행실태 점검 결과를 붙임과 같이 보고합니다.

붙임 ○○학교 개인정보 보호 내부 관리계획 이행실태 점검표 1부. 끝.

★

교장

협조자

시행 ○○학교-0000 (0000. 00. 00.) 접수 ()

우 00000 경상남도 ○○○ / http://www.

전화 000-0000 /전송 055-000-0000 / ○○○@○○○ / 비공개(5)

내부 관리계획 이행실태 점검표 예시

개인정보 내부 관리계획 이행실태 점검표

□ 점검일 :

점검항목	세부 점검내용	점검결과
내부 관리계획 수립 및 책임자 공개	1. 개인정보 보호 내부 관리계획 수립 여부 - 12가지 필수 내용이 포함되어 있는지 확인	☐ 예 ☐ 아니오
	1-1. 개인정보 보호책임자의 지정에 관한 사항	☐ 예 ☐ 아니오
	1-2. 개인정보 보호책임자 및 취급자의 역할 및 책임에 관한 사항	☐ 예 ☐ 아니오
	1-3. 개인정보취급자에 대한 교육에 관한 사항	☐ 예 ☐ 아니오
	1-4. 접근 권한의 관리에 관한 사항	☐ 예 ☐ 아니오
	1-5. 접근 통제에 관한 사항	☐ 예 ☐ 아니오
	1-6. 개인정보의 암호화 조치에 관한 사항	☐ 예 ☐ 아니오
	1-7. 접속기록 보관 및 점검에 관한 사항	☐ 예 ☐ 아니오
	1-8. 악성프로그램 등 방지에 관한 사항	☐ 예 ☐ 아니오
	1-9. 물리적 안전조치에 관한 사항	☐ 예 ☐ 아니오
	1-10. 개인정보 보호조직에 관한 구성 및 운영에 관한 사항	☐ 예 ☐ 아니오
	1-11. 개인정보 유출사고 대응 계획 수립·시행에 관한 사항	☐ 예 ☐ 아니오
	1-12. 개인정보 처리업무를 위탁하는 경우 수탁자에 대한 관리 및 감독에 관한 사항	☐ 예 ☐ 아니오
개인정보 보호 교육	2. 개인정보 처리방침에 개인정보 보호책임자를 현행화하여 공개 여부 ※ 각급 학교 개인정보 보호책임자: 교장	☐ 예 ☐ 아니오
	3. 개인정보 보호 연간 교육계획 수립 여부 - 교육목적 및 대상(책임자, 담당자, 취급자, 수탁자), 내용, 일정 및 방법을 포함한 당해연도 종합적인 연간 교육계획 수립	☐ 예 ☐ 아니오
	4. 개인정보 보호 교육 실시 여부	☐ 예 ☐ 아니오
	4-1. 개인정보 보호책임자 CPO전문교육 이수 여부 * 온라인 또는 오프라인, 도교육청 온라인전달연수(gnleckr)	☐ 예 ☐ 아니오
	4-2. 개인정보 보호담당자 교육 이수 여부 * 온라인 또는 오프라인, 도교육청 온라인전달연수(gnleckr)	☐ 예 ☐ 아니오
	4-3. 취급자(전직원) 교육 실시 여부 - 대상()명 / 참석()명, 교육이수율()%	☐ 예 ☐ 아니오

점검항목	세부 점검내용	점검결과
접근권한 관리	5. 개인정보처리시스템에 대한 접근 권한 관리 여부 - 개인정보처리시스템에 접근 권한을 최소한의 범위로 부여 여부 - 전보, 퇴직 등 인사이동 시 권한 변경 및 말소 여부 - 사용자별 접속 계정 발급 및 공유금지의 이행 여부 - 권한부여, 변경, 말소에 대한 내역을 기록·보관(3년) 여부 ※ 개인정보처리시스템: 나이스, K-에듀파인, 학교홈페이지 등 ※ 교육정보과-3659(2021. 6. 3.)"교육정보시스템 사용자 및 권한관리 지침 개정"참고	☐ 예 ☐ 아니오
접속기록 보관 및 점검	6. 자체 운영·관리하는 개인정보처리시스템이 있을 경우 접속기록 점검 및 보관 여부 - 자체 운영·관리하는 개인정보처리시스템이 없을 경우 '해당없음'에 표기 * 업무포털, 통합홈페이지 등 통합하여 관리하는 시스템은 통합 운영·관리 기관에서 접속기록 보관·점검함	☐ 예 ☐ 아니오 ☐ 해당없음
접근통제 및 단말기 안전조치	7. 취급중인 개인정보가 인터넷 홈페이지, P2P, 공유설정 등을 통해 공개유출되지 않도록 업무용PC, 모바일 기기 등에 접근통제 조치 여부 - PC 운영체제나 보안프로그램 등의 접근통제 조치 - 비밀번호 설정 - 화면보호기 비밀번호 설정(10분 이상)	☐ 예 ☐ 아니오
암호화	8. 업무용PC에 고유키별정보(주민등록번호 등) 저장 시 암호화 여부 - PC개인정보관리시스템(Privacy-i)을 통한 암호화 여부	☐ 예 ☐ 아니오
악성프로그램 방지	9. 업무용PC에 백신 소프트웨어 설치 운영 및 자동 업데이트 여부	☐ 예 ☐ 아니오
물리적 안전조치	10. 전산실, 평가실 등 개인정보 보관 장소의 물리적 통제 절차 적정 여부 예) 통제구역 지정, 출입명부 관리, 잠금장치 설정 등	☐ 예 ☐ 아니오
	11. 개인정보 포함 서류, 휴대용 저장매체는 잠금장치가 있는 안전한 장소에 보관 여부	☐ 예 ☐ 아니오
개인정보 처리 위탁	12. 개인정보 처리 위탁 시 문서화 여부 - 필수사항을 포함한 위탁계약서(개인정보 처리 표준위탁계약서) * PC유지관리, 졸업앨범제작 등	☐ 예 ☐ 아니오
목적 외 이용 및 제3자 제공	13. 개인정보의 목적 외 이용 및 목적 외 제3자 제공 절차 준수 여부 예) 국회, 경찰서, 법원, 병무청 등 자료 제공 13-1. 개인정보 보호책임자의 승인을 거쳐 제공받는자에게 문서로 보호조치 요청 13-2. 개인정보의 목적 외 이용 및 제3자 제공 대장 기록 관리 13-3. 목적 외 이용 및 제3자 제공 내역을 홈페이지 공개 ※ 정보주체의 별도 동의 범위의 수사를 위해 제공한 경우 공개 제외	☐ 예 ☐ 아니오 ☐ 해당없음 ☐ 예 ☐ 아니오 ☐ 해당없음 ☐ 예 ☐ 아니오 ☐ 해당없음
개인정보 파기수행	14. 목적 달성, 보유기간 경과한 개인정보(파일)의 파기 여부 - 파기 요청서 및 개인정보파일 파기 관리대장 기록 관리	☐ 예 ☐ 아니오

※ 연 1회 이상 이행실태 점검 실시 후 개인정보 보호책임자(교장) 내부결재를 득하여 보관